MARCO DE EVALUACIÓN DE CIBERSEGURIDAD

LLM-Sec

Evaluación de la postura de ciberseguridad en plataformas que integran LLM

Alineado a OWASP LLM Top 10:2025,
ISO/IEC 33001 e ISO/IEC 27002:2022

Valentina Paz Campos Olguín

Universidad de Santiago de Chile | DIINF

Versión 1.0 | Julio 2026

Control de versiones

Versión	Fecha	Autor	Descripción
1.0	Julio 2026	V. Campos Olguín	Versión inicial del documento del marco.

Índice general

Control de versiones **2**

1. Introducción **1**
1.1. Propósito del documento . . . 1
1.2. Alcance . . . 1
1.3. Audiencia . . . 1
1.4. Referencias normativas . . . 2
1.5. Convenciones del documento . . . 2

2. Modelo de madurez **3**
2.1. Identificación de activos del sistema RAG . . . 3
2.2. Valoración de riesgo por activo . . . 5
2.2.1. Escala de valoración . . . 5
2.2.2. Matriz de riesgo . . . 5
2.2.3. Interpretación y priorización . . . 5
2.2.4. Trazabilidad hacia las subdimensiones . . . 6
2.3. Estructura del modelo . . . 7
2.4. Niveles de madurez . . . 7
2.5. Subdimensiones . . . 8
2.5.1. D1: Protección de entrada . . . 8
2.5.2. D2: Control de contexto RAG . . . 9
2.5.3. D3: Gestión de salida . . . 9
2.5.4. D4: Monitoreo y trazabilidad . . . 9
2.5.5. D5: Gobernanza organizacional . . . 10
2.6. Regla de piso mínimo . . . 10

3. Taxonomía de controles **11**
3.1. Estructura de los controles . . . 11
3.2. D1: Protección de entrada . . . 11
3.3. D2: Control de contexto RAG . . . 13
3.4. D3: Gestión de salida . . . 16
3.5. D4: Monitoreo y trazabilidad . . . 17
3.6. D5: Gobernanza organizacional . . . 19
3.7. Distribución de controles . . . 21

4. Perfiles organizacionales **22**
4.1. P1: PYME . . . 22
4.1.1. Trayectoria recomendada . . . 22

4.1.2. Controles prioritarios . . . 23
4.2. P2: Mediana/Grande . . . 23
4.2.1. Trayectoria recomendada . . . 23
4.2.2. Controles prioritarios . . . 24
4.3. P3: Crítica regulada . . . 26
4.3.1. Trayectoria recomendada . . . 26
4.3.2. Obligaciones regulatorias aplicables . . . 26
4.3.3. Controles prioritarios . . . 26

5. Guía de evaluación **29**
5.1. Flujo de evaluación . . . 29
5.2. Nivel verificado y nivel declarado . . . 29
5.3. Criterios de verificación por fuente de evidencia . . . 30
5.3.1. Configuración . . . 30
5.3.2. Experimental . . . 30
5.3.3. Declarativo . . . 30
5.4. Matriz RACI . . . 30
5.5. Ciclo de mejora . . . 31

A. Resumen de controles por nivel **32**

B. Mapeo normativo **33**

Capítulo 1

Introducción

1.1 Propósito del documento

Este documento especifica el marco LLM-Sec, un instrumento de evaluación de la postura de ciberseguridad para plataformas que integran modelos de lenguaje de gran escala (LLM) en arquitecturas de generación aumentada por recuperación (RAG). El marco combina un modelo de madurez de seis niveles con una taxonomía de 62 controles operacionales, proporcionando al evaluador criterios cuantificables y reproducibles para determinar el estado de seguridad de un sistema RAG.

El presente documento es un artefacto independiente de la tesis que lo valida experimentalmente. Su estructura permite su aplicación autónoma por parte de cualquier organización, sin requerir acceso al experimento de laboratorio descrito en la tesis.

1.2 Alcance

El marco LLM-Sec está diseñado para evaluar sistemas RAG que cumplan las siguientes condiciones:

- Utilizan un modelo de lenguaje como componente de inferencia.
- Incorporan una base de datos vectorial como fuente de contexto.
- Operan en un entorno donde la entrada del usuario se procesa en lenguaje natural.

El marco cubre cuatro categorías de amenaza del OWASP LLM Top 10:2025 pertinentes al flujo RAG: LLM01 (Prompt Injection), LLM02 (Sensitive Information Disclosure), LLM07 (System Prompt Leakage) y LLM08 (Vector and Embedding Weaknesses).

1.3 Audiencia

- **Evaluadores de seguridad:** profesionales que realizan auditorías de sistemas RAG.
- **Equipos de desarrollo:** responsables de implementar controles en el ciclo de vida del sistema.
- **Oficiales de cumplimiento:** encargados de verificar la adherencia a normativa vigente.
- **Dirección:** tomadores de decisiones que requieren una visión ejecutiva del nivel de riesgo.

1.4 Referencias normativas

El marco LLM-Sec se ancla a las siguientes referencias:

Referencias principales

OWASP	LLM Top 10:2025
ISO/IEC 33001	Evaluación de capacidad de procesos
ISO/IEC 27002:2022	Controles de seguridad de la información
NIST AI RMF	Marco de gestión de riesgos de IA
MITRE ATLAS	Tácticas adversariales para sistemas de IA
Ley 21.663	Marco de Ciberseguridad (Chile)
Ley 21.719	Protección de Datos Personales (Chile)
Boletín 16821-19	Proyecto de Ley de Inteligencia Artificial (Chile)

1.5 Convenciones del documento

A lo largo de este documento se utilizan las siguientes convenciones visuales:

- Los controles se identifican con `C01` – `C62`.
- Los niveles de madurez se representan con etiquetas: N0 N1 N2 N3 N4 N5.
- Los tipos funcionales se distinguen por color: Preventivo Detectivo Correctivo Gobernanza.
- Las fuentes de evidencia se indican como: Configuración Experimental Declarativo.

Capítulo 2

Modelo de madurez

2.1 Identificación de activos del sistema RAG

Toda evaluación de seguridad requiere, como paso previo a la definición de controles, la identificación de los activos sobre los cuales opera el riesgo. Esta práctica está establecida en el NIST CSF 2.0, cuya función *Identify* define la gestión de activos como condición necesaria antes de seleccionar e implementar medidas de protección. En consecuencia, esta sección declara los activos del sistema RAG que el marco LLM-Sec tiene por objeto proteger, delimitando el perímetro de evaluación sobre el cual se articulan los componentes del marco.

A diferencia de un LLM aislado, los sistemas RAG exponen una superficie de ataque distribuida en múltiples componentes encadenados, cada uno de los cuales constituye un activo susceptible de ser comprometido de forma independiente. La Tabla 2.1 presenta los cinco activos identificados, su descripción funcional dentro del flujo RAG y el riesgo principal asociado a cada uno.

Cuadro 2.1: Activos del sistema RAG y riesgos asociados.

ID	Activo	Riesgo principal	Referencia
A1	LLM	Manipulación del comportamiento del modelo mediante inyección de instrucciones maliciosas en lenguaje natural.	LLM01:2025
A2	Base de datos vectorial	Recuperación no autorizada de fragmentos indexados e intoxicación del corpus mediante documentos maliciosos.	LLM08:2025
A3	Corpus de conocimiento	Exposición de información sensible contenida en los documentos indexados mediante consultas diseñadas para exfiltración.	LLM02:2025
A4	Canales de entrada y salida	Transporte de instrucciones maliciosas en la entrada y filtración de información del corpus o del prompt del sistema en la salida.	LLM01, LLM07
A5	Mecanismos de acceso y sesión	Acceso no autorizado a información sensible por ausencia de control de identidad o segregación de permisos.	NIST AI RMF

Cada activo ocupa una posición específica dentro del flujo de inferencia RAG, lo que determina qué vectores de amenaza le son aplicables y, en consecuencia, qué subdimensión del modelo de madurez lo cubre:

Mapeo activo → subdimensión

Activo	Etapa del flujo	Subdimensión	Vectores
A1 (LLM)	Inferencia	D1, D3	LLM01
A2 (Base vectorial)	Recuperación	D2	LLM08
A3 (Corpus)	Recuperación	D2	LLM02
A4 (Canales E/S)	Entrada y salida	D1, D3	LLM01, LLM07
A5 (Acceso y sesión)	Transversal	D4, D5	Transversal

Este mapeo justifica la existencia de exactamente cinco subdimensiones y no un número arbitrario: cada subdimensión protege un subconjunto distinto del flujo RAG, y el modelo de madurez evalúa cada uno de forma independiente antes de agregar un nivel global mediante la regla de piso mínimo (sección 2.6).

La identificación de activos no constituye un componente del marco sino una condición previa a su aplicación. LLM-Sec es un instrumento de evaluación de postura que recibe como entrada un sistema cuyo perímetro ya ha sido delimitado y produce como salida un nivel de madurez verificado. Esta separación es coherente con el diseño agnóstico al dominio: al no fijar el perímetro de activos dentro del marco, este puede aplicarse a cualquier sistema RAG con independencia de su dominio de despliegue.

2.2 Valoración de riesgo por activo

Una vez identificados los activos, el paso siguiente consiste en valorar el riesgo asociado a cada uno. El marco LLM-Sec adopta la definición de riesgo de la Ley 21.663, que lo formula en términos de **probabilidad de ocurrencia** de un incidente y el **impacto de sus consecuencias**. Esta formulación exige que la valoración no sea cualitativa sino cuantificable, lo que justifica el uso de una matriz de riesgo como instrumento de priorización.

2.2.1 Escala de valoración

La valoración emplea dos ejes, cada uno con tres niveles:

Escalas de probabilidad e impacto

Probabilidad de explotación

	Nivel	Criterio
3	Alta	Explotable con herramientas automatizadas de acceso público.
2	Media	Requiere conocimiento técnico específico del sistema.
1	Baja	Requiere acceso privilegiado o condiciones poco frecuentes.

Impacto de compromiso

	Nivel	Criterio
3	Alto	Exfiltración de datos sensibles o pérdida de control del modelo.
2	Medio	Degradación del servicio o exposición parcial de información.
1	Bajo	Impacto operacional contenido, sin exposición de datos.

2.2.2 Matriz de riesgo

La Tabla 2.2 presenta la valoración de riesgo para cada activo identificado en la sección anterior. El nivel de riesgo se obtiene como el producto de probabilidad e impacto, clasificado en tres categorías: **Alto** (≥ 6), **Medio** ($3{-}4$) y **Bajo** (≤ 2).

Cuadro 2.2: Matriz de valoración de riesgo por activo del sistema RAG.

ID	Activo	Probabilidad	Impacto	Riesgo	Clasificación
A4	Canales de E/S	3 (Alta)	3 (Alto)	9	Alto
A1	LLM	3 (Alta)	3 (Alto)	9	Alto
A3	Corpus	3 (Alta)	3 (Alto)	9	Alto
A2	Base vectorial	2 (Media)	3 (Alto)	6	Alto
A5	Acceso y sesión	1 (Baja)	3 (Alto)	3	Medio

2.2.3 Interpretación y priorización

La valoración revela tres hallazgos que condicionan el diseño del modelo de madurez y la distribución de controles:

1. **Los canales de entrada/salida, el LLM y el corpus concentran el riesgo más alto.** Esto se debe a que los vectores LLM01, LLM02 y LLM07 son explotables con herramientas automatizadas de acceso público (como Garak), sin requerir acceso privilegiado al sistema. Esta condición explica que las subdimensiones D1 (Protección de entrada), D2 (Control de contexto RAG) y D3 (Gestión de salida) concentren el mayor volumen de controles en la taxonomía: 17, 18 y 10 respectivamente, frente a 9 de D4 y 15 de D5.

2. **La base vectorial presenta riesgo alto con probabilidad media.** A diferencia de los canales de E/S, la explotación de LLM08 requiere conocimiento específico de la infraestructura de recuperación (tipo de base vectorial, estrategia de indexación, configuración de similitud). No obstante, el impacto de su compromiso es alto porque afecta la integridad de todo el corpus recuperable. Esto justifica que D2 sea la subdimensión con mayor densidad de controles (18), cubriendo tanto los riesgos de alta probabilidad del corpus (LLM02) como los de probabilidad media de la infraestructura vectorial (LLM08).

3. **Los mecanismos de acceso y sesión presentan riesgo medio.** Su probabilidad de explotación es baja en el contexto de un sistema RAG desplegado en red controlada, pero el impacto de su compromiso sigue siendo alto. Esto justifica que el control de acceso (C22) se clasifique como declarativo: su implementación es imprescindible en producción, pero su verificación experimental queda fuera del alcance de un laboratorio controlado en TRL 4.

La valoración presentada corresponde a un sistema RAG genérico. Cada organización debe recalcular la probabilidad y el impacto según su contexto de despliegue específico, utilizando las escalas definidas. El perfil organizacional (P1, P2 o P3) orienta la interpretación del nivel de riesgo aceptable, pero no reemplaza esta valoración.

2.2.4 Trazabilidad hacia las subdimensiones

La siguiente tabla sintetiza cómo la valoración de riesgo justifica la estructura del modelo de madurez:

Riesgo → subdimensión → densidad de controles

Activo	Riesgo	Subdimensión	Controles	Prioridad
A4 (Canales E/S)	Alto (9)	D1, D3	17 + 10	Máxima
A1 (LLM)	Alto (9)	D1, D3	17 + 10	Máxima
A3 (Corpus)	Alto (9)	D2	18	Máxima
A2 (Base vectorial)	Alto (6)	D2	18	Alta
A5 (Acceso y sesión)	Medio (3)	D4, D5	9 + 15	Media

Esta trazabilidad garantiza que la distribución de controles del marco no es arbitraria, sino proporcional al riesgo valorado de cada activo. Las subdimensiones con mayor densidad de controles (D1, D2, D3) corresponden a los activos con mayor nivel de riesgo, mientras que D4 y D5, asociadas a activos de riesgo medio, priorizan la observación y la gobernanza sobre la intervención directa.

2.3 Estructura del modelo

A partir de los activos identificados y su valoración de riesgo (secciones 2.1 y 2.2), el modelo de madurez LLM-Sec define seis niveles (N0 a N5) que representan una escala ordinal de la postura de ciberseguridad de un sistema RAG. La progresión es acumulativa: alcanzar un nivel N_k requiere satisfacer todos los criterios de los niveles N_0 a N_{k-1}. Las distancias entre niveles no son uniformes; cada nivel refleja un salto cualitativo en la solidez de los procesos, no un incremento lineal. Esta propiedad tiene una consecuencia estadística directa: el coeficiente apropiado para medir la correlación entre el nivel asignado y la resistencia experimental observada es Spearman, dado que no se asumen distancias iguales entre categorías.

El modelo evalúa cinco subdimensiones derivadas de los ítems del OWASP LLM Top 10:2025 pertinentes al flujo RAG, cuya trazabilidad hacia los activos del sistema se estableció en la sección 2.1. Dado que no existe un modelo de madurez estandarizado para arquitecturas RAG en la literatura actual, esta derivación constituye una contribución original del marco.

2.4 Niveles de madurez

N0: Inexistente

Sin consciencia de seguridad. No existen controles, políticas ni identificación de riesgos asociados al sistema RAG. Estado previo al despliegue del sistema; no genera artefactos de evaluación.

N1: Inicial

Los riesgos son reconocidos pero no se han implementado controles para abordarlos. El sistema opera sin mecanismos de protección activos, asumiendo implícitamente los riesgos existentes. Corresponde a un sistema RAG desplegado sin capa defensiva.

N2: Reactivo

Controles básicos implementados de forma parcial o no sistemática. Respuesta ante incidentes conocidos, no preventiva. Se evidencia mediante la activación de una capa defensiva con configuración por defecto; la tasa de filtrado de ataques es positiva pero variable entre categorías.

N3: Definido

Controles formalmente definidos, documentados y aplicados de forma consistente. Umbrales de detección establecidos antes de la operación. Los logs de la capa defensiva son trazables por escáner y categoría de amenaza.

N4: Gestionado

Seguridad gestionada cuantitativamente. Métricas de desempeño definidas y controles ajustados según resultados medidos. El nivel de correlación entre la puntuación del checklist y la resistencia experimental es estadísticamente significativo.

N5: Optimizado

Mejora continua. Controles actualizados proactivamente ante nuevas amenazas documentadas. Marco revisado periódicamente e integrado al ciclo de gestión de riesgos organizacional. Requiere validación longitudinal y en múltiples dominios.

2.5 Subdimensiones

Subdimensiones del modelo LLM-Sec

ID	Nombre	OWASP	Captura
D1	Protección de entrada	LLM01, LLM02	Validación y sanitización de prompts
D2	Control de contexto RAG	LLM02, LLM08	Acceso y exposición de la base vectorial
D3	Gestión de salida	LLM02, LLM07	Filtrado y control de respuestas
D4	Monitoreo y trazabilidad	Todos	Logging, alertas y auditoría
D5	Gobernanza organizacional	—	Roles, políticas y cultura de seguridad

2.5.1 D1: Protección de entrada

La subdimensión D1 agrupa los controles orientados a la validación y sanitización de prompts de entrada, constituyendo la primera línea de defensa del flujo RAG. Opera sobre los canales de entrada y el LLM, interceptando la amenaza antes de que alcance la capa de inferencia. Su verificación combina evidencia de configuración (archivos YAML, prompt del sistema) con validación experimental (resultados de auditoría ofensiva).

La subdimensión D1 representa el primer punto de contacto entre el usuario y el sistema RAG, constituyendo la primera línea de defensa para garantizar una secuencia de acciones segura. Los activos sobre los que opera son los canales de entrada y el propio LLM, cuyo comportamiento puede ser manipulado si el prompt no es validado previamente.

Ficha del proceso D1: Protección de entrada

Propósito	Interceptar amenazas semánticas antes de que alcancen la capa de inferencia, mediante validación y sanitización del prompt de entrada.
Activos que protege	Canales de entrada y LLM.
Vector OWASP asociado	LLM01:2025

Entradas y salidas del proceso D1

Desde	Entrada	Salida	Hacia
Usuario	Prompt en lenguaje natural	Prompt sanitizado y validado	D2
Sistema	System prompt configurado	Registro de prompts rechazados	D4
Configuración	Políticas de restricción (YAML)	Alerta de intento de inyección detectado	D4
D5	Política de uso aceptable	—	—

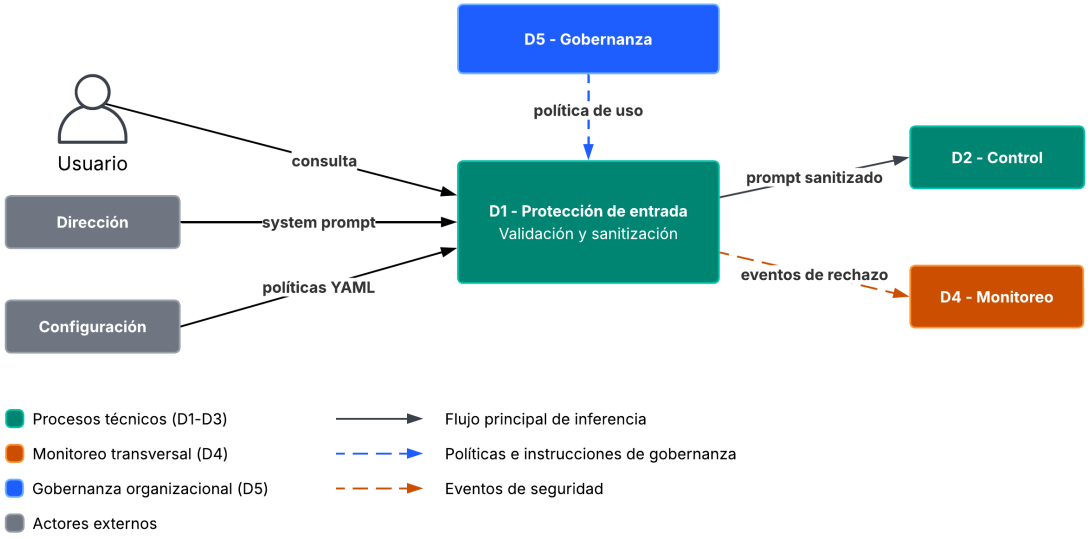


Figura 2.1: Flujo de entradas y salidas del proceso D1: Protección de entrada. Elaboración propia.

2.5.2 D2: Control de contexto RAG

La subdimensión D2 abarca los controles que regulan el acceso, la exposición y la integridad de la base de datos vectorial y el corpus de conocimiento. Opera sobre la etapa de recuperación del flujo RAG, donde los fragmentos de contexto son seleccionados y entregados al modelo como parte del prompt aumentado.

2.5.3 D3: Gestión de salida

La subdimensión D3 comprende los controles que filtran y regulan las respuestas generadas por el modelo antes de entregarlas al usuario. Opera sobre el canal de salida del flujo RAG, constituyendo la última línea de defensa contra la exfiltración de información sensible y la fuga del prompt del sistema.

2.5.4 D4: Monitoreo y trazabilidad

La subdimensión D4 opera de forma transversal sobre el sistema RAG completo. Su naturaleza es observacional: no interviene sobre el flujo sino que lo registra. Sus entradas son eventos

generados por las tres subdimensiones anteriores y sus salidas son exclusivamente artefactos de auditoría.

D4 no define controles de nivel N1 porque el monitoreo mínimo viable requiere que el sistema disponga de algún mecanismo activo de registro, condición que no se cumple en un sistema sin capa defensiva. Un sistema en esa condición se clasifica como no conforme en esta subdimensión.

2.5.5 D5: Gobernanza organizacional

La subdimensión D5 opera de forma transversal sobre la organización completa, no sobre una etapa técnica específica del flujo RAG. Captura las obligaciones institucionales de gestión de la seguridad: definición de roles y responsabilidades, políticas de uso, cumplimiento normativo y mejora continua del marco. Su verificación es exclusivamente declarativa, dado que requiere métodos cualitativos como auditorías organizacionales o revisión documental, incompatibles con un entorno de laboratorio controlado.

D5 provee insumos normativos e institucionales a las demás subdimensiones, actuando como el proceso de gobernanza que sustenta la operación segura del sistema RAG en su conjunto. Sus entradas son marcos normativos y retroalimentación de D4, y sus salidas son políticas e instrumentos de gobernanza que condicionan la operación del resto del sistema.

2.6 Regla de piso mínimo

El nivel global L del sistema se determina como:

$$L = \text{mín}(d_1, d_2, d_3, d_4, d_5)$$

donde d_i es el nivel verificado de la subdimensión i. La justificación subyacente es que la postura de seguridad de un sistema es tan sólida como su componente más débil. A modo de ejemplo, si D1, D2 y D3 alcanzan nivel 4 pero D4 alcanza nivel 2, el nivel global verificado es 2.

Dado que D5 opera exclusivamente con fuente de evidencia declarativa, su nivel no es verificable mediante experimento de laboratorio. El marco distingue por tanto entre **nivel verificado** (determinado mediante evidencia experimental o de configuración, aplicable a D1–D4) y **nivel declarado** (determinado mediante lista de chequeo sin evidencia técnica directa, aplicable a D5).

En cuanto a la ponderación dentro de cada subdimensión, todos los controles de un mismo nivel tienen peso equivalente. Esta decisión se justifica porque la ausencia de literatura previa comparable impide anclar ponderaciones diferenciales a evidencia empírica; asignar pesos arbitrarios introduciría un sesgo no justificable.

Capítulo 3

Taxonomía de controles

3.1 Estructura de los controles

Cada control se caracteriza por cinco atributos:

1. **Nivel de madurez** (N1 a N5): determina en qué nivel del modelo se requiere su implementación.
2. **Tipo funcional**: preventivo, detectivo, correctivo o gobernanza, según el momento en que actúa respecto al evento de seguridad (ISO/IEC 27002:2022).
3. **Fuente de evidencia**: configuración (archivos YAML, prompt del sistema), experimental (resultados de auditoría ofensiva) o declarativo (verificación por lista de chequeo).
4. **Descripción**: acción específica que el control requiere.
5. **Fuente normativa**: referencia al estándar o legislación que lo origina.

Un control puede satisfacer más de un tipo funcional simultáneamente, consistente con el modelo de atributos de ISO/IEC 27002:2022. Por ejemplo, un escáner de salida que identifica y suprime contenido sensible actúa como control detectivo y correctivo en una misma operación.

Todos los controles de un mismo nivel tienen peso equivalente dentro de su subdimensión.

El conjunto completo comprende 62 controles distribuidos en cinco subdimensiones y cinco niveles de madurez. Las secciones siguientes presentan los controles organizados por subdimensión.

3.2 D1: Protección de entrada

La subdimensión D1 agrupa 17 controles distribuidos en cinco niveles de madurez: 8 en N1, 3 en N2, 2 en N3, 2 en N4 y 2 en N5. El predominio de controles preventivos refleja la naturaleza de esta subdimensión: interceptar la amenaza antes de que alcance la capa de inferencia.

C01 N1

Limitar longitud máxima del prompt de entrada.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025

C02 N1

Sanitizar el prompt de entrada eliminando caracteres y patrones de control.

Tipo: Preventivo **Evidencia:** Experimental **Fuente:** LLM01:2025

C06 N1

Segregar e identificar contenido externo en el prompt mediante delimitadores explícitos.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C13 N1

Limitar el volumen total de contexto inyectado al LLM por sesión.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C15 N1

Restringir el rol, capacidades y limitaciones del modelo en el prompt del sistema.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C16 N1

Interponer un proxy de seguridad externo e independiente del LLM.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C21 N1

Restringir credenciales y tokens de API al entorno de código.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C30 N1

Verificar procedencia e integridad del modelo mediante *checksums* antes del despliegue.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663, LLM08:2025

C03 N2

Detectar patrones sintácticos de inyección en el prompt de entrada.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM01:2025

C04 N2

Validar la relevancia semántica del prompt respecto al dominio autorizado.

Tipo: Preventivo **Evidencia:** Experimental **Fuente:** LLM01:2025

C05 N2

Ocultar el contenido del prompt del sistema al usuario, impidiendo su extracción.

Tipo: Preventivo **Evidencia:** Experimental **Fuente:** LLM01:2025, LLM07:2025

C31 N3

Registrar y auditar todos los prompts rechazados con el motivo del rechazo.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM01:2025

C32 N3

Validar que el prompt del sistema no ha sido modificado entre sesiones.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM07:2025

C33 N4

Ajustar dinámicamente los umbrales de detección de inyección según tasas de falsos positivos observadas.

Tipo: Preventivo **Evidencia:** Declarativo **Fuente:** LLM01:2025

C34 N4

Medir y reportar periódicamente la tasa de prompts rechazados por categoría de ataque.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM01:2025

C35 N5

Actualizar los patrones de detección ante nuevas técnicas de inyección documentadas.

Tipo: Preventivo **Evidencia:** Declarativo **Fuente:** LLM01:2025

C36 N5

Revisar y ajustar el prompt del sistema ante cambios en el modelo base.

Tipo: Preventivo **Evidencia:** Declarativo **Fuente:** LLM01:2025

3.3 D2: Control de contexto RAG

La subdimensión D2 agrupa 18 controles orientados a regular el acceso, la exposición y la integridad de la base de datos vectorial y el corpus de conocimiento. La distribución por nivel refleja una progresión desde controles básicos de particionamiento y sanitización (N1) hasta mecanismos de auditoría avanzada y mejora continua (N5).

C06 N1

Segregar e identificar contenido externo en el prompt mediante delimitadores explícitos.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C07 N1

Restringir las fuentes de información del modelo a documentos autorizados y verificados.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM02:2025

C10 N1

Controlar la cantidad de fragmentos recuperados por consulta para limitar exposición del corpus.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM02:2025

C13 N1

Limitar el volumen total de contexto inyectado al LLM por sesión.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM02:2025

C15 N1

Restringir el rol, capacidades y limitaciones del modelo en el prompt del sistema.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C16 N1

Interponer un proxy de seguridad externo e independiente del LLM.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C21 N1

Restringir credenciales y tokens de API al entorno de código.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C30 N1

Verificar procedencia e integridad del modelo mediante *checksums* antes del despliegue.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663, LLM08:2025

C08 N2

Particionar el *vector store* por nivel de sensibilidad para prevenir acceso cruzado.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM02:2025, LLM08:2025

C09 N2

Validar integridad del corpus y fragmentos recuperados antes de inyectarlos al contexto del LLM.

Tipo: Preventivo/Detectivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM08:2025

C11 N2

Validar semánticamente la *query* generada hacia el *vector store* antes de ejecutar el *retrieval*.

Tipo: Preventivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM08:2025

C14 N2

Suprimir o redactar metadatos de documentos indexados en las respuestas del modelo.

Tipo: Correctivo **Evidencia:** Experimental **Fuente:** LLM02:2025

C17 N2

Restringir respuestas a información fundamentada en el contexto recuperado.

Tipo: Preventivo/Detectivo **Evidencia:** Experimental **Fuente:** LLM02:2025

C22 N2

Controlar y auditar el acceso por sesión a los documentos del *vector store*.

Tipo: Preventivo/Detectivo **Evidencia:** Declarativo **Fuente:** LLM02:2025

C12 N3

Detectar consultas al *vector store* diseñadas para reconocimiento sistemático del corpus.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM08:2025

C62 N3

Mantener un registro versionado del corpus indexado que permita identificar qué documentos estaban activos en cada sesión y rastrear cambios entre versiones.

Tipo: Detectivo **Evidencia:** Configuración **Fuente:** LLM02:2025, LLM08:2025

C37 N4

Medir y reportar periódicamente la tasa de recuperación de fragmentos sensibles ante consultas de prueba.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM02:2025

C38 N4

Ajustar los parámetros de *retrieval* según métricas de exposición observadas.

Tipo: Preventivo **Evidencia:** Declarativo **Fuente:** LLM02:2025

C39 N5

Actualizar el particionamiento del *vector store* ante cambios en la clasificación de sensibilidad del corpus.

Tipo: Preventivo **Evidencia:** Declarativo **Fuente:** LLM02:2025, LLM08:2025

C40 N5

Revisar proactivamente los fragmentos indexados ante nuevas amenazas de exfiltración documentadas.

Tipo: Preventivo **Evidencia:** Declarativo **Fuente:** LLM02:2025, LLM08:2025

3.4 D3: Gestión de salida

La subdimensión D3 comprende 10 controles que filtran y regulan las respuestas generadas por el modelo antes de entregarlas al usuario, constituyendo la última línea de defensa contra la exfiltración de información sensible y la fuga del prompt del sistema.

C16 N1

Interponer un proxy de seguridad externo e independiente del LLM.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025, LLM07:2025

C14 N2

Suprimir o redactar metadatos de documentos indexados en las respuestas del modelo.

Tipo: Correctivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM07:2025

C17 N2

Restringir respuestas a información fundamentada en el contexto recuperado.

Tipo: Preventivo/Detectivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM07:2025

C18 N2

Sanitizar la salida del modelo eliminando contenido con patrones sintácticos sensibles.

Tipo: Correctivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM07:2025

C19 N2

Detectar y suprimir fragmentos marcados como confidenciales en la salida del modelo.

Tipo: Detectivo/Correctivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM07:2025

C20 N3

Validar que la salida no reproduzca literalmente fragmentos del corpus sensible indexado.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM02:2025, LLM07:2025

C41 N4

Ajustar dinámicamente los umbrales de sanitización según métricas de falsos positivos en la salida.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM02:2025, LLM07:2025

C42 N4

Medir y reportar la tasa de supresión de fragmentos confidenciales por tipo de ataque.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM02:2025, LLM07:2025

C43 N5

Revisar y actualizar los patrones de detección de contenido sensible en la salida ante nuevas técnicas de exfitlración.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM02:2025, LLM07:2025

C44 N5

Incorporar retroalimentación de incidentes reales al conjunto de patrones de sanitización.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM02:2025, LLM07:2025

3.5 D4: Monitoreo y trazabilidad

La subdimensión D4 agrupa 9 controles de naturaleza observacional, distribuidos a partir de N2. D4 no define controles de nivel N1 porque el monitoreo mínimo viable requiere que el sistema disponga de algún mecanismo activo de registro, condición que no se cumple en un sistema sin capa defensiva.

C26 N2

Definir y documentar la política de umbrales de detección y bloqueo previo a la operación.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C27 N2

Establecer procedimiento formal de notificación de seguridad ante autoridades.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C28 N2

Definir política de retención y eliminación de datos de sesión conforme a normativa aplicable.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.719

C23 N3

Registrar cada decisión de bloqueo en la entrada y salida con identificación del mecanismo y vector.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM01:2025, LLM02:2025, LLM07:2025, LLM08:2025

C25 N3

Registrar y analizar la latencia del flujo de inferencia para detectar comportamiento anómalo.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM01:2025, LLM02:2025, LLM07:2025, LLM08:2025

C29 N3

Documentar y ejecutar plan de pruebas de seguridad ofensiva previo a cada despliegue.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C24 N4

Monitorear patrones de consulta anómalos que sugieran reconocimiento sistemático del corpus.

Tipo: Detectivo **Evidencia:** Experimental **Fuente:** LLM01:2025, LLM02:2025, LLM07:2025, LLM08:2025

C45 N5

Revisar y actualizar los patrones de detección de anomalías ante nuevas amenazas documentadas.

Tipo: Detectivo **Evidencia:** Declarativo **Fuente:** LLM01:2025, LLM02:2025, LLM07:2025, LLM08:2025

C46 N5

Incorporar retroalimentación de incidentes al sistema de alertas de forma sistemática y periódica.

Tipo: Correctivo **Evidencia:** Declarativo **Fuente:** LLM01:2025, LLM02:2025, LLM07:2025, LLM08:2025

3.6 D5: Gobernanza organizacional

La subdimensión D5 agrupa 15 controles de tipo exclusivamente Gobernanza con fuente de evidencia Declarativa. Estos controles capturan las obligaciones institucionales derivadas de la Ley 21.663, la Ley 21.719, el NIST AI RMF y el Proyecto de Ley de IA.

C47 N1

Designar formalmente un responsable de la seguridad del sistema RAG con atribuciones documentadas.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C48 N1

Declarar el sistema RAG como activo de información sujeto a las obligaciones de la normativa vigente.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C49 N1

Establecer política de uso aceptable del sistema RAG ccesible a todos los usuarios.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.719

C61 N1

Mantener un inventario actualizado de los activos del sistema RAG, incluyendo modelo, corpus, base vectorial y componentes de seguridad, conforme a lo definido en la sección 2.1.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C50 N2

Adoptar y adaptar la matriz RACI del marco LLM-Sec, asignando los roles genéricos definidos a personas o cargos concretos de la organización.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.663

C51 N2

Establecer procedimiento formal de gestión de accesos que regule altas, bajas y modificaciones de permisos sobre el sistema.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.719

C52 N2

Documentar el inventario de datos personales procesados por el sistema RAG conforme a las obligaciones del responsable de tratamiento.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Ley 21.719

C53 N3

Establecer un programa formal de capacitación en seguridad de sistemas LLM dirigido a los roles definidos en la matriz RACI.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** NIST AI RMF

C54 N3

Definir y ejecutar un ciclo de revisión periódica del marco LLM-Sec con frecuencia mínima anual.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** NIST AI RMF

C55 N3

Documentar y comunicar formalmente los riesgos residuales del sistema RAG a la dirección de la organización.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** NIST AI RMF

C60 N3

Realizar y documentar una evaluación formal de riesgos del sistema RAG con frecuenca mínima anual o ante cambios significativos en el modelo o el corpus.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** NIST AI RMF

C56 N4

Establecer métricas de desempeño de la gobernanza de seguridad y reportarlas periódicamente a la dirección.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Proyecto Ley IA

C57 N4

Implementar un proceso formal de gestión de riesgos de IA que clasifique el sistema RAG según su nivel de criticidad.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Proyecto Ley IA

C58 N5

Revisar y actualizar proactivamente el marco LLM-Sec ante cambios normativos, nuevas amenazas o modificaciones del modelo base.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Proyecto Ley IA

C59 N5

Incorporar lecciones aprendidas de incidentes de seguridad al ciclo de mejora continua del marco de gobernanza.

Tipo: Gobernanza **Evidencia:** Declarativo **Fuente:** Proyecto Ley IA

3.7 Distribución de controles

La siguiente tabla resume la distribución de los 62 controles por subdimensión y nivel de madurez.

Distribución de controles: subdimensión × nivel

Subdim.	N1	N2	N3	N4	N5	Total
D1	8	3	2	2	2	17
D2	6	5	3	2	2	18
D3	3	3	2	1	1	10
D4	0	3	3	1	2	9
D5	4	2	4	2	3	15
Total	21	16	14	8	10	**62**

Nota

Verificar que los totales de esta tabla coincidan con las tablas de la tesis. Algunos controles pueden aparecer en más de una subdimensión dado que su función de protección es transversal.

Capítulo 4

Perfiles organizacionales

Los perfiles organizacionales orientan la interpretación del nivel de madurez asignado según el tipo de organización. No modifican los criterios de asignación ni la definición de los niveles; únicamente establecen el nivel mínimo recomendado y el nivel objetivo según las obligaciones regulatorias aplicables.

Resumen de perfiles

Perfil	Tipo	Nivel mínimo	Nivel objetivo	Descripción
P1	PYME	N1	N3	Organizaciones pequeñas y medianas
P2	Mediana/Grande	N2	N4	Organizaciones con infraestructura formal
P3	Crítica regulada	N3	N5	Infraestructura crítica, sector regulado

4.1 P1: PYME

El perfil P1 está diseñado para pequeñas y medianas empresas que despliegan sistemas RAG con recursos limitados de ciberseguridad. El nivel mínimo recomendado es N1 y el nivel objetivo es N3.

4.1.1 Trayectoria recomendada

1. **N1 (Inicial):** Implementar los controles preventivos básicos de D1 y D2. Desplegar un prompt del sistema con instrucciones de seguridad. Activar la capa defensiva con configuración por defecto.
2. **N2 (Reactivo):** Configurar umbrales de detección y habilitar logging básico (D4). Establecer política de uso aceptable (D5).
3. **N3 (Definido):** Documentar formalmente los controles implementados. Calibrar umbrales basándose en resultados de auditoría. Establecer trazabilidad completa por escáner.

4.1.2 Controles prioritarios

El perfil P1 debe priorizar los controles de N1 con fuente de evidencia Configuración, dado que su implementación no requiere desarrollo adicional sino parametrización de componentes existentes. La Tabla 4.1 los ordena por subdimensión y costo estimado de implementación.

Cuadro 4.1: Controles prioritarios para el perfil P1 (PYME).

Ctrl	Nivel	Dim.	Costo	Acción requerida
Implementación inmediata (configuración, sin desarrollo)				
C15	N1	D1, D2	Bajo	Redactar prompt del sistema con restricciones de rol.
C01	N1	D1	Bajo	Configurar límite de longitud del prompt.
C06	N1	D1, D2	Bajo	Agregar delimitadores al contexto inyectado.
C10	N1	D2	Bajo	Limitar fragmentos recuperados por consulta.
C13	N1	D1, D2	Bajo	Limitar volumen total de contexto por sesión.
C07	N1	D2	Bajo	Restringir fuentes a documentos autorizados.
C21	N1	D1, D2	Bajo	Variables de entorno para credenciales.
C16	N1	D1, D2, D3	Medio	Desplegar proxy de seguridad (ej. LLM Guard).
Fase siguiente (requiere proxy activo, niveles N2–N3)				
C02	N1	D1	Medio	Activar sanitización de entrada en el proxy.
C08	N2	D2	Medio	Particionar vector store por sensibilidad.
C18	N2	D3	Medio	Activar sanitización de salida en el proxy.
C19	N2	D3	Medio	Activar detección de contenido confidencial.
C26	N2	D4	Bajo	Documentar política de umbrales.
C23	N3	D4	Medio	Habilitar logging de decisiones de bloqueo.
C31	N3	D1	Medio	Registrar prompts rechazados con motivo.

El costo estimado es relativo al contexto PYME. **Bajo** indica parametrización sin componentes adicionales. **Medio** indica despliegue o configuración de un componente nuevo (proxy, particiones). Los controles de D5 (gobernanza) aplican transversalmente a todos los perfiles y se listan en la sección 3.6.

4.2 P2: Mediana/Grande

El perfil P2 aplica a organizaciones medianas y grandes con infraestructura formal de seguridad de la información. El nivel mínimo recomendado es N2 y el nivel objetivo es N4.

4.2.1 Trayectoria recomendada

1. **N2 (Reactivo):** Todos los controles de N1 implementados. Configuración activa de la capa defensiva con umbrales ajustados. Monitoreo básico operativo.
2. **N3 (Definido):** Controles documentados y aplicados consistentemente. Auditoría ofensiva periódica. Matriz RACI asignada.
3. **N4 (Gestionado):** Métricas de desempeño definidas (TFA, LAS). Controles ajustados según resultados cuantitativos. Monitoreo de patrones de consulta anómalos.

4.2.2 Controles prioritarios

El perfil P2 parte de N2 como nivel mínimo y apunta a N4. Los controles prioritarios se concentran en la activación de mecanismos detectivos y el inicio de la gestión cuantitativa. Se asume que los controles de N1 ya están implementados.

Cuadro 4.2: Controles prioritarios para el perfil P2 (Mediana/Grande).

Ctrl	Nivel	Dim.	Costo	Acción requerida
Consolidación del nivel N2 (detectivos y particionamiento)				
C08	N2	D2	Medio	Particionar vector store por nivel de sensibilidad.
C09	N2	D2	Medio	Validar integridad de fragmentos antes de inyección al contexto.
C11	N2	D2	Medio	Validar semánticamente la query antes del retrieval.
C14	N2	D2, D3	Medio	Suprimir metadatos de documentos en las respuestas.
C17	N2	D2, D3	Medio	Restringir respuestas a información fundamentada en el contexto.
C18	N2	D3	Medio	Activar sanitización de salida en el proxy.
C19	N2	D3	Medio	Activar detección de contenido confidencial en la salida.
C22	N2	D2	Alto	Implementar control de acceso por sesión al vector store.
C26	N2	D4	Bajo	Documentar política de umbrales de detección y bloqueo.
C27	N2	D4	Bajo	Establecer procedimiento de notificación ante autoridades.
C28	N2	D4	Bajo	Definir política de retención y eliminación de datos de sesión.
C50	N2	D5	Bajo	Instanciar la matriz RACI con cargos concretos.
C51	N2	D5	Medio	Establecer procedimiento formal de gestión de accesos.
C52	N2	D5	Medio	Documentar inventario de datos personales procesados.
Tránsito a N3 (trazabilidad y auditoría formal)				
C03	N2	D1	Medio	Activar detección de patrones sintácticos de inyección.
C04	N2	D1	Medio	Validar relevancia semántica del prompt respecto al dominio.
C05	N2	D1	Medio	Ocultar contenido del prompt del sistema al usuario.
C23	N3	D4	Medio	Habilitar logging de decisiones de bloqueo con vector e identificador.
C25	N3	D4	Medio	Registrar y analizar latencia del flujo de inferencia.
C31	N3	D1	Medio	Registrar prompts rechazados con motivo del rechazo.
C32	N3	D1	Bajo	Validar integridad del prompt del sistema entre sesiones.
C12	N3	D2	Alto	Detectar consultas de reconocimiento sistemático del corpus.
C20	N3	D3	Medio	Validar que la salida no reproduzca literalmente fragmentos sensibles.
C62	N3	D2	Medio	Mantener registro versionado del corpus indexado.
C29	N3	D4	Medio	Documentar y ejecutar plan de pruebas ofensivas por despliegue.
C53	N3	D5	Medio	Establecer programa de capacitación en seguridad LLM.
C54	N3	D5	Bajo	Definir ciclo de revisión periódica del marco.
C55	N3	D5	Bajo	Documentar y comunicar riesgos residuales a la dirección.
C60	N3	D5	Medio	Realizar evaluación formal de riesgos del sistema RAG.
Nivel objetivo N4 (gestión cuantitativa)				
C33	N4	D1	Alto	Ajustar umbrales de detección según tasas de falsos positivos.
C34	N4	D1	Medio	Medir y reportar tasa de prompts rechazados por categoría.
C24	N4	D4	Alto	Monitorear patrones de consulta anómalos.
C37	N4	D2	Medio	Medir tasa de recuperación de fragmentos sensibles ante consultas de prueba.
C38	N4	D2	Alto	Ajustar parámetros de retrieval según métricas de exposición.
C41	N4	D3	Alto	Ajustar umbrales de sanitización según falsos positivos en salida.
C42	N4	D3	Medio	Medir tasa de supresión de fragmentos confidenciales por tipo de ataque.
C56	N4	D5	Medio	Establecer métricas de desempeño de la gobernanza de seguridad.
C57	N4	D5	Medio	Clasificar el sistema RAG según nivel de criticidad.

El costo estimado es relativo al contexto de una organización mediana o grande con equipo de seguridad dedicado. **Bajo** indica documentación o parametrización. **Medio** indica configuración de componentes existentes o desarrollo de procedimientos. **Alto** indica desarrollo, integración de componentes nuevos o capacidad analítica especializada.

4.3 P3: Crítica regulada

El perfil P3 aplica a organizaciones que operan infraestructura crítica o pertenecen a sectores regulados, donde las obligaciones de la Ley 21.663 y la Ley 21.719 imponen requisitos formales de ciberseguridad y protección de datos. El nivel mínimo recomendado es N3 y el nivel objetivo es N5.

4.3.1 Trayectoria recomendada

1. **N3 (Definido):** Todos los controles de N1–N2 implementados y documentados. Trazabilidad completa. Evaluación de riesgos formal.
2. **N4 (Gestionado):** Gestión cuantitativa de la seguridad. Proceso formal de gestión de riesgos de IA con clasificación por criticidad. Reportes periódicos a dirección.
3. **N5 (Optimizado):** Mejora continua integrada. Marco revisado ante cambios normativos o nuevas amenazas. Lecciones aprendidas incorporadas al ciclo de gobernanza.

4.3.2 Obligaciones regulatorias aplicables

Las organizaciones bajo el perfil P3 deben considerar especialmente:

- **Ley 21.663:** obligaciones de notificación de incidentes, designación de responsable de seguridad, inventario de activos de información.
- **Ley 21.719:** obligaciones del responsable de tratamiento, inventario de datos personales procesados por el sistema RAG.
- **Proyecto de Ley de IA:** clasificación del sistema según nivel de criticidad, métricas de desempeño de gobernanza.

4.3.3 Controles prioritarios

El perfil P3 parte de N3 como nivel mínimo y apunta a N5. Los controles prioritarios enfatizan la gestión cuantitativa, la mejora continua y el cumplimiento normativo de la Ley 21.663, la Ley 21.719 y el Proyecto de Ley de IA. Se asume que los controles de N1 a N2 ya están implementados y que la organización cuenta con los recursos para sostener un ciclo de mejora continua.

Cuadro 4.3: Controles prioritarios para el perfil P3 (Crítica regulada).

Ctrl	Nivel	Dim.	Costo	Acción requerida
Consolidación del nivel N3 (trazabilidad completa y gobernanza formal)				
C23	N3	D4	Medio	Logging completo de decisiones de bloqueo con vector e identificador.
C25	N3	D4	Medio	Registro y análisis de latencia para detección de anomalías.
C31	N3	D1	Medio	Registro de prompts rechazados con motivo del rechazo.
C32	N3	D1	Bajo	Validación de integridad del prompt del sistema entre sesiones.
C12	N3	D2	Alto	Detección de consultas de reconocimiento sistemático del corpus.
C20	N3	D3	Medio	Validación de no reproducción literal de fragmentos sensibles.
C62	N3	D2	Medio	Registro versionado del corpus indexado por sesión.
C29	N3	D4	Medio	Plan de pruebas ofensivas documentado y ejecutado por despliegue.
C53	N3	D5	Medio	Programa de capacitación en seguridad LLM para roles RACI.
C54	N3	D5	Bajo	Ciclo de revisión periódica del marco con frecuencia mínima anual.
C55	N3	D5	Bajo	Comunicación formal de riesgos residuales a la dirección.
C60	N3	D5	Medio	Evaluación formal de riesgos con metodología documentada.
Tránsito a N4 (gestión cuantitativa y cumplimiento normativo)				
C33	N4	D1	Alto	Ajuste dinámico de umbrales según tasas de falsos positivos.
C34	N4	D1	Medio	Reporte periódico de tasa de rechazo por categoría de ataque.
C24	N4	D4	Alto	Monitoreo de patrones de consulta anómalos.
C37	N4	D2	Medio	Medición periódica de tasa de recuperación de fragmentos sensibles.
C38	N4	D2	Alto	Ajuste de parámetros de retrieval según métricas de exposición.
C41	N4	D3	Alto	Ajuste dinámico de umbrales de sanitización de salida.
C42	N4	D3	Medio	Reporte de tasa de supresión de fragmentos confidenciales.
C56	N4	D5	Medio	Métricas de desempeño de gobernanza reportadas a la dirección.
C57	N4	D5	Medio	Clasificación formal del sistema según nivel de criticidad.
Nivel objetivo N5 (mejora continua y actualización proactiva)				
C35	N5	D1	Alto	Actualizar patrones de detección ante nuevas técnicas de inyección.
C36	N5	D1	Alto	Revisar prompt del sistema ante cambios en el modelo base.
C39	N5	D2	Alto	Actualizar particionamiento ante cambios de clasificación del corpus.
C40	N5	D2	Alto	Revisión proactiva de fragmentos ante nuevas amenazas de exfiltración.
C43	N5	D3	Alto	Actualizar patrones de detección de contenido sensible en salida.
C44	N5	D3	Alto	Incorporar retroalimentación de incidentes a patrones de sanitización.
C45	N5	D4	Alto	Actualizar patrones de detección de anomalías ante nuevas amenazas.
C46	N5	D4	Alto	Incorporar retroalimentación de incidentes al sistema de alertas.
C58	N5	D5	Medio	Actualización proactiva del marco ante cambios normativos.
C59	N5	D5	Medio	Incorporar lecciones aprendidas al ciclo de mejora continua.

El costo estimado es relativo al contexto de infraestructura crítica con obligaciones regulatorias formales. **Bajo** indica documentación. **Medio** indica procedimientos o configuración. **Alto** indica capacidad analítica especializada, desarrollo de componentes o procesos de mejora continua que requieren personal dedicado. Las organizaciones bajo este perfil deben considerar especialmente los controles anclados a la Ley 21.663 (notificación de incidentes, inventario de activos), la Ley 21.719 (inventario de datos personales, gestión de accesos) y el Proyecto de Ley de IA (clasificación por criticidad, métricas de gobernanza).

Capítulo 5

Guía de evaluación

5.1 Flujo de evaluación

El proceso de evaluación del marco LLM-Sec sigue seis pasos secuenciales:

1. **Selección del perfil organizacional:** identificar el perfil (P1, P2 o P3) que corresponde a la organización según su tipo y obligaciones regulatorias.
2. **Evaluación de controles:** verificar cada control de las subdimensiones D1 a D5 utilizando la fuente de evidencia correspondiente (configuración, experimental o declarativa).
3. **Asignación de nivel por subdimensión:** el nivel de cada subdimensión es el mayor nivel cuyos controles están completamente implementados, respetando la progresión acumulativa.
4. **Cálculo del nivel global:** aplicar la regla de piso mínimo: $L = \text{mín}(d_1, d_2, d_3, d_4, d_5)$.
5. **Análisis de brechas:** identificar la distancia entre el nivel verificado y el nivel objetivo del perfil seleccionado.
6. **Plan de remediación:** priorizar la implementación de controles faltantes según el nivel objetivo, enfocándose primero en la subdimensión que actúa como piso.

5.2 Nivel verificado y nivel declarado

El marco distingue dos tipos de nivel asignado según la fuente de evidencia utilizada:

> **Nivel verificado:** determinado mediante evidencia experimental (resultados de auditoría ofensiva, logs de la capa defensiva) o de configuración (archivos YAML, prompt del sistema). Aplica a las subdimensiones D1, D2, D3 y D4.
> **Nivel declarado:** determinado mediante lista de chequeo sin evidencia técnica directa, basado en auditoría organizacional o revisión documental. Aplica a la subdimensión D5.

Al reportar el resultado de una evaluación, el evaluador debe indicar explícitamente qué subdimensiones fueron verificadas y cuáles fueron declaradas. El nivel global debe acompañarse de esta distinción para evitar interpretaciones que asuman verificación completa.

5.3 Criterios de verificación por fuente de evidencia

5.3.1 Configuración

El control se verifica inspeccionando la declaración explícita en los archivos de configuración del sistema. Ejemplos: presencia de umbrales en el archivo YAML de la capa defensiva, instrucciones de seguridad en el prompt del sistema, particionamiento de la base vectorial.

5.3.2 Experimental

El control se verifica mediante la ejecución de pruebas de auditoría ofensiva contra el sistema bajo evaluación. El resultado se expresa como una métrica cuantificable (tasa de filtrado, latencia, cobertura). La herramienta de auditoría debe ejecutar probes alineados a las categorías OWASP cubiertas por el control.

5.3.3 Declarativo

El control se verifica mediante revisión documental o entrevista. El evaluador solicita evidencia de la existencia de la política, procedimiento o asignación de roles descrita por el control.

5.4 Matriz RACI

El marco define roles genéricos que cada organización debe mapear a personas o cargos concretos. La matriz RACI establece las responsabilidades para las actividades principales del ciclo de evaluación.

La gestión efectiva de la seguridad de un sistema RAG requiere que cada actividad tenga un responsable claramente definido. Siguiendo el modelo de COBIT 4.1, el marco LLM-Sec provee una matriz RACI como artefacto central de gobernanza, que define los roles genéricos involucrados en la operación del sistema junto con su nivel de participación en cada actividad.

Los roles definidos son genéricos por diseño: no corresponden a personas específicas sino a funciones organizacionales. Cada organización debe instanciar la matriz asignando cada rol a los cargos o personas concretas de su estructura, conforme al control C50. Esta instanciación es condición necesaria para que los controles de D5 sean auditables.

La Tabla 5.1 presenta las actividades principales del marco y la asignación de roles según los criterios R (Responsable), A (*Accountable*), C (Consultado) e I (Informado).

Cuadro 5.1: Matriz RACI del marco LLM-Sec.

Actividad	Resp. Seguridad	Operador Técnico	Prop. Corpus	Dirección	Cumplimiento
Designar responsable de seguridad del sistema RAG	A	I	I	R	C
Declarar el sistema RAG como activo de información	R	C	C	A	I
Mantener inventario de activos actualizado	R	C	C	I	A
Gestionar accesos al sistema	R	A	C	I	C
Aplicar lista de chequeo LLM-Sec	R	A	C	I	C
Revisar y actualizar el marco periódicamente	R	C	C	A	C
Notificar incidentes de seguridad	R	C	I	A	C
Ejecutar plan de pruebas ofensivas	A	R	I	I	C
Capacitar a los roles en seguridad LLM	R	C	C	A	C
Reportar métricas de gobernanza a la dirección	R	C	I	A	C

R = Responsable (ejecuta) • **A** = *Accountable* (rinde cuentas) • **C** = Consultado • **I** = Informado

5.5 Ciclo de mejora

Ante brechas identificadas entre el nivel verificado y el nivel objetivo, el evaluador debe:

1. Identificar la subdimensión que actúa como piso mínimo.
2. Priorizar los controles faltantes de esa subdimensión en el nivel inmediatamente superior.
3. Implementar los controles priorizados.
4. Re-ejecutar la evaluación para verificar el tránsito de nivel.

Este ciclo es iterativo y se repite hasta alcanzar el nivel objetivo del perfil organizacional o hasta que los riesgos residuales sean formalmente aceptados y documentados por la dirección.

Apéndice A

Resumen de controles por nivel

Apéndice B

Mapeo normativo